

ai-os-new

Build / Deploy / Config Re-Audit Report

Verification audit after bug fixes. Original: 13 findings. Remaining: 13 findings.

Severity	Count
CRITICAL	1
HIGH	4
MEDIUM	5
LOW	3
Total	13

BLD
-01

CRITICAL

Nginx template variables never substituted - container won't start

Files: Dockerfile, docker/nginx.conf

Problem: \${API_UPSTREAM:-default} shell syntax not valid nginx. File copied to conf.d/ not templates/. envsubst never runs. Container fails to start.

Fix: Copy to /etc/nginx/templates/default.conf.template for auto-envsubst.

BLD
-02

HIGH

CSP blocks Google Fonts CDN in production

Files: index.css, docker/nginx.conf

Problem: index.css @imports Google Fonts. CSP style-src/font-src doesn't allow fonts.googleapis.com/fonts.gstatic.com. Fonts silently fail in Docker.

Fix: Self-host fonts or add Google CDN origins to CSP.

BLD
-03

HIGH

VITE_PROXY_URL points to non-existent /fetch endpoint

Files: .env.example, sandbox-service.ts, tool-executor.ts

Problem: Defaults to localhost:3001/fetch. Port 3001 is sync-server (no /fetch route). Port 3002 is cors-proxy (expects ?url= at root). Both 404.

Fix: Change to http://localhost:3002. Remove /fetch path.

BLD
-04

HIGH

slaMode validation values differ from contract type

Files: contracts/settings.ts, settings-service.ts

Problem: Contract: BALANCED|PERFORMANCE|ECONOMY|EXPERIMENTAL|FREE_FIRST.
LOW_LATENCY|HIGH_QUALITY|BALANCED|ECONOMY|FREE_FIRST. TypeScript compiles but runtime rejects valid values.

Validation:

Fix: Align validation with contract type.

BLD
-05

HIGH

CONFIG never deep-frozen at init - mutations possible

Files: config-registry.ts

Problem: Exported as Readonly<ConfigRegistry> but rawConfig never frozen at module load. deepFreeze only called inside setConfig/replaceConfig. Initial config fully mutable.

Fix: Add deepFreeze(rawConfig) immediately after definition and before export.

BLD
-06

MEDIUM

CORS proxy hardcodes localhost:5173 origin

Files: cors-proxy.mjs

Problem: Returns hardcoded Access-Control-Allow-Origin: http://localhost:5173. Breaks non-default ports and production. No OPTIONS preflight handler.

Fix: Read CORS_ORIGIN from env var. Add OPTIONS handler.

BLD
-07

MEDIUM

vite-plugin-wasm in dependencies not devDependencies

Files: package.json

Problem: Build plugin listed in dependencies bloats production installs. Should be devDependencies.

Fix: Move to devDependencies.

BLD
-08

MEDIUM

ws in devDependencies but required at runtime by sync-server

Files: package.json, sync-server.mjs

Problem: sync-server imports ws but it's in devDependencies. npm ci --omit=dev would crash sync-server.

Fix: Move ws to dependencies.

BLD
-09

MEDIUM

Root nginx.conf inconsistent with Docker configs

Files: nginx.conf

Problem: Differs significantly: hardcoded proxy_pass, different CSP, privileged ports, deprecated ssl_prefer_server_ciphers. Could mislead operators.

Fix: Remove or update root nginx.conf. Add comment that Docker configs are authoritative.

BLD - 10	MEDIUM	Duplicate isPrivateIP in cors-proxy - CGNAT range missing
-------------	--------	---

Files: cors-proxy.mjs

Problem: Function defined twice. Second shadows first and is missing 100.64.0.0/10 CGNAT check. CGNAT addresses not blocked.

Fix: Remove duplicate second definition. Keep only first (more complete).

BLD - 11	LOW	Sandbox SSRF 172.x check incomplete (mitigated)
-------------	-----	---

Files: sandbox-service.ts

Problem: host.startsWith('172.16.') only covers /16, not full /12 range. Currently mitigated by catch-all bare-IP regex.

Fix: Use isPrivateIP utility from kernel/utls/network.ts.

BLD - 12	LOW	Duplicate model name in provider catalog
-------------	-----	--

Files: provider-catalog-service.ts

Problem: gemini-3.1-flash-lite appears twice in Google models list. Could cause duplicate UI entries.

Fix: Remove duplicate or add intended second model.

BLD - 13	LOW	Deprecated ssl_prefer_server_ciphers in nginx-ssl.conf
-------------	-----	--

Files: docker/nginx-ssl.conf

Problem: Directive deprecated in nginx 1.25.1. Generates warnings. Irrelevant with TLS 1.3.

Fix: Remove the line.